Relationship Matrices of the MARISMA-IoT Pattern

Table 1. Matrix of Objective-Domain-Family of Threats of MARISMA-IoT

Domain	Control	Nefarious activity / Abuse	Eavesdropping / Interception / Hijacking	Outages	Damage / Loss (IT Assets)	Failures / Malfunctions	Disaster	Physical attacks	Legal
Organizational	Policies for information security	X	X	X	X	X	X	X	X
	Information security roles and responsibilities	X	X	X	X	X	X	X	X
	Segregation of duties	X	X						X
	Management responsibilities	X	X	X	X	X	X	X	X
	Contact with authorities	X	X	X	X	X	X	X	X
	Contact with special interest groups	X	X						X
	Threat intelligence	X	X	X	X	X	X	X	X
	Information security in project management	X	X	X	X	X	X	X	X
	Inventory of information and other associated assets	X	X	X	X	X	X	X	X
	Acceptable use of information and other associated assets	X	X	X	X	X		X	X
	Return of assets		X		X				X
	Classification of information	X	X		X				X
	Labelling of information								X
	Information transfer	X	X		X				X
	Access control	X	X		X			X	
	Identity management	X	X		X				X
	Authentication information	X	X		X				X
	Access rights	X	X		X				X
	Information security in supplier relationships	X	X		X	X			X
	Addressing information security within supplier agreements	X	X		X	X			X
	Managing information security in the ICT supply chain	X	X			X			X
	Monitoring, review and change management of supplier services			X		X			X
	Information security for use of cloud services		X		X				X
	Information security incident management planning and preparation	X	X	X	X	X	X	X	X
	Assessment and decision on information security events	X	X	X	X	X	X	X	X
	Response to information security incidents	X	X	X	X	X	X	X	X
	Learning from information security incidents	X	X	X	X	X	X	X	X
	Collection of evidence								X
	Information security during disruption		X	X					
	ICT readiness for business continuity			X					
	Legal, statutory, regulatory and contractual requirements								X
	Intellectual property rights								X
	Protection of records	X			X				X
	Privacy and protection of PII	X	X		X				X
	Independent review of information security	X	X	X	X	X	X	X	X
	Compliance with policies, rules and standards for information security	X	X		X	X		X	X
	Documented operating procedures	X	X		X	X			X
People	Screening	X							X
	Terms and conditions of employment	X							X
	Information security awareness, education and training	X	X		X	X			X
	Disciplinary process	X							X
	Responsibilities after termination or change of employment	X			X				X
	Confidentiality or non-disclosure agreements				X				X
	Remote working	X	X		X	X			X
	Information security event reporting	X	X		X	X			X
Physical	Physical security perimeters				X			X	X
	Physical entry				X			X	X
	Securing offices, rooms and facilities				X			X	
	Physical security monitoring	X		X			X	X	
	Protecting against physical and environmental threats			X			X		
	Working in secure areas							X	
	Clear desk and clear screen	X	X		X				
	Equipment siting and protection			X			X	X	
	Security of assets off-premises				X			X	
	Storage media	X			X				
	Supporting utilities			X					
	Cabling security		X	X				X	
	Equipment maintenance	X		X		X			
	Secure disposal or re-use of equipment	X	X		X				

Table 1. Matrix of Objective-Domain-Family of Threats of MARISMA-IoT									
Domain	**Control**	**Nefarious activity / Abuse**	**Eavesdropping / Interception / Hijacking**	**Outages**	**Damage / Loss (IT Assets)**	**Failures / Malfunctions**	**Disaster**	**Physical attacks**	**Legal**
Technological	User endpoint devices	X	X		X				X
	Privileged access rights	X			X	X			X
	Information access restriction	X	X		X	X			X
	Access to source code	X	X		X	X			X
	Secure authentication	X	X		X	X			X
	Capacity management			X		X			
	Protection against malware	X			X	X			
	Management of technical vulnerabilities	X	X		X	X			
	Configuration management	X	X		X	X			
	Information deletion	X			X				X
	Data masking	X	X		X				
	Data leakage prevention	X			X				
	Information backup	X			X		X		
	Redundancy of information processing facilities			X			X		
	Logging	X	X	X	X	X			X
	Monitoring activities	X	X	X	X	X			X
	Clock synchronization								X
	Use of privileged utility programs	X			X	X			
	Installation of software on operational systems	X			X	X			
	Network security	X	X			X			
	Security of network services	X	X			X			
	Segregation of networks	X	X			X			
	Web filtering	X	X		X				
	Use of cryptography	X	X		X				X
	Secure development life cycle	X			X	X			X
	Application security requirements	X			X	X			X
	Secure system architecture and engineering principles	X	X	X	X	X	X		X
	Secure coding	X			X	X			X
	Security testing in development and acceptance	X			X	X			X
	Outsourced development	X			X	X			X
	Separation of development, test and production environments	X			X	X			X
	Change management	X		X		X			
	Test information	X	X		X				
	Protection of information systems during audit testing	X			X				

Table 2. Matrix of Types of Assets - Threats - Dimensions for MARISMA-IoT

Family of Threats	Types of Threats	Family of Assets								
		IoT Devices	Other IoT Ecosystem Devices	Communications	Infrastructure	Platform & Backend	Decision Making	Applications & Services	Information	Audio/Visual
Nefarious activity / Abuse	Malware	P, S, C, RL, I, D, L, RP	P, S, C, RL, I, D, L, RP			P, S, C, RL, I, D, L, RP				P, S, C, RL, I, D, L, RP
	Exploit Kits	P, S, C, RL, I, D, L, RP	P, S, C, RL, I, D, L, RP		S, C, RL, I, D, L, RP					P, S, C, RL, I, D, L, RP
	Targeted attacks				P, S, C, RL, I, D, L, RP	P, S, C, RL, I, D, L, RP			P, I, D, L, RP	
	DDoS	C, RL, D, L, RP	C, RL, D, L, RP		C, RL, D, L, RP	C, RL, D, L, RP				C, RL, D, L, RP
	Counterfeit by malicious devices	P, S, C, RL, I, D, L, RP	P, S, C, RL, I, D, L, RP		S, C, RL, I, D, L, RP					P, S, C, RL, I, D, L, RP
	Attacks on privacy	P, I, L, RP, S	P, I, L, RP, S			P, I, L, RP, S			P, I, L, RP, S	P, I, L, RP, S
	Modification of information	I, C, RL, L, RP	I, C, RL, L, RP			I, C, RL, L, RP			I, C, L, RP	I, C, RL, L, RP
Eavesdropping / Interception / Hijacking	Man in the middle	P, I, C, RL, D, L, RP		P, I, C, RL, D					P, I, D, L, RP	P, I, C, RL, D, L, RP
	IoT communication protocol hijacking	P, I, C, RL, D, L, RP, S			P, I, C, RL, D, L, RP, S		P, I, C, RL, D, L, RP		P, I, D, L, RP	P, I, C, RL, D, L, RP, S
	Interception of information	P, C, L, RP	P, C, L, RP	P, C	P, C, L, RP				P, C, L, RP	P, C, L, RP
	Network reconnaissance	P, C, L, RP		P, C, L, RP	P, C, L, RP					P, C, L, RP
	Session hijacking	P, I, C, RL, D, L, RP		P, I, C, RL, D, L, RP					P, I, D, L, RP	P, I, C, RL, D, L, RP
	Information gathering	P, C, L, RP	P, C, L, RP	P, C	P, C, L, RP				P, L, RP	P, C, L, RP
	Replay of messages	P, I, C, RL, D, L, RP				P, I, C, RL, D, L, RP			P, I, C, RL, D, L, RP	P, I, C, RL, D, L, RP
Outages	Network Outage			C, RL, D, L, RP	C, RL, D, L, RP					
	Failures of devices	C, RL, D, L, RP, S	C, RL, D, L, RP, S		C, RL, D, L, RP, S					C, RL, D, L, RP, S
	Failure of system					C, RL, D, L, RP	C, RL, D, L, RP	C, RL, D, L, RP		
	Loss of support services	C, RL, D, L, RP	C, RL, D, L, RP	C, RL, D, L, RP	C, RL, D, L, RP	C, RL, D, L, RP	C, RL, D, L, RP	C, RL, D, L, RP	C, RL, D, L, RP	C, RL, D, L, RP
Damage / Loss (IT Assets)	Data / Sensitive information leakage	P, L, RP, C, S	P, L, RP, C, S			P, L, RP, C, S			P, L, RP, C, S	P, L, RP, C, S
Failures / Malfunctions	Software vulnerabilities	P, S, C, RL, I, D, L, RP	P, S, C, RL, I, D, L, RP		S, C, RL, I, D, L, RP	P, S, C, RL, I, D, L, RP		P, S, C, RL, I, D, L, RP		P, S, C, RL, I, D, L, RP
	Third parties failures	C, RL, D, L, RP, I, P	C, RL, D, L, RP, I, P		C, RL, D, L, RP	C, RL, D, L, RP, I, P		C, RL, D, L, RP, I, P		C, RL, D, L, RP, I, P
Disaster	Natural Disaster	RL, I, D	RL, I, D		RL, I, D					RL, I, D
	Environmental Disaster	RL, I, D	RL, I, D		RL, I, D					RL, I, D
Physical attacks	Device modification	S, C, RL, I, D, L, RP, P	S, C, RL, I, D, L, RP, P		S, C, RL, I, D, L, RP					S, C, RL, I, D, L, RP, P
	Device destruction (sabotage)	S, RL, I, D	S, RL, I, D		S, RL, I, D					RL, I, D
Legal	Violation of laws or regulations / Breach of legislation	D, L, RP	D, L, RP			D, L, RP		D, L, RP	D, L, RP	D, L, RP
	Judiciary decision / Court order	P, D, L, RP				P, D, L, RP			P, I, D, L, RP	P, D, L, RP
	No-IP company domains seizure	C, RL, D, L, RP	C, RL, D, L, RP	C, RL, D, L, RP	C, RL, D, L, RP	C, RL, D, L, RP	C, RL, D, L, RP	C, RL, D, L, RP		C, RL, D, L, RP
	Failure to meet contractual requirements	C, L, RP	C, L, RP		C, L, RP	C, L, RP	C, L, RP	C, L, RP	C, L, RP	C, L, RP

Dimensions: P: Privacy; S: Safety; C: Reliability; RL: Resilience; I: Integrity; D: Availability; L: Legality; RP: Accountability.